Application des notes

Owner: KIHEL Mohammed
Reviewer:
Contributors:
Date Generated: Sun Oct 25 2026

Executive Summary

High level system description

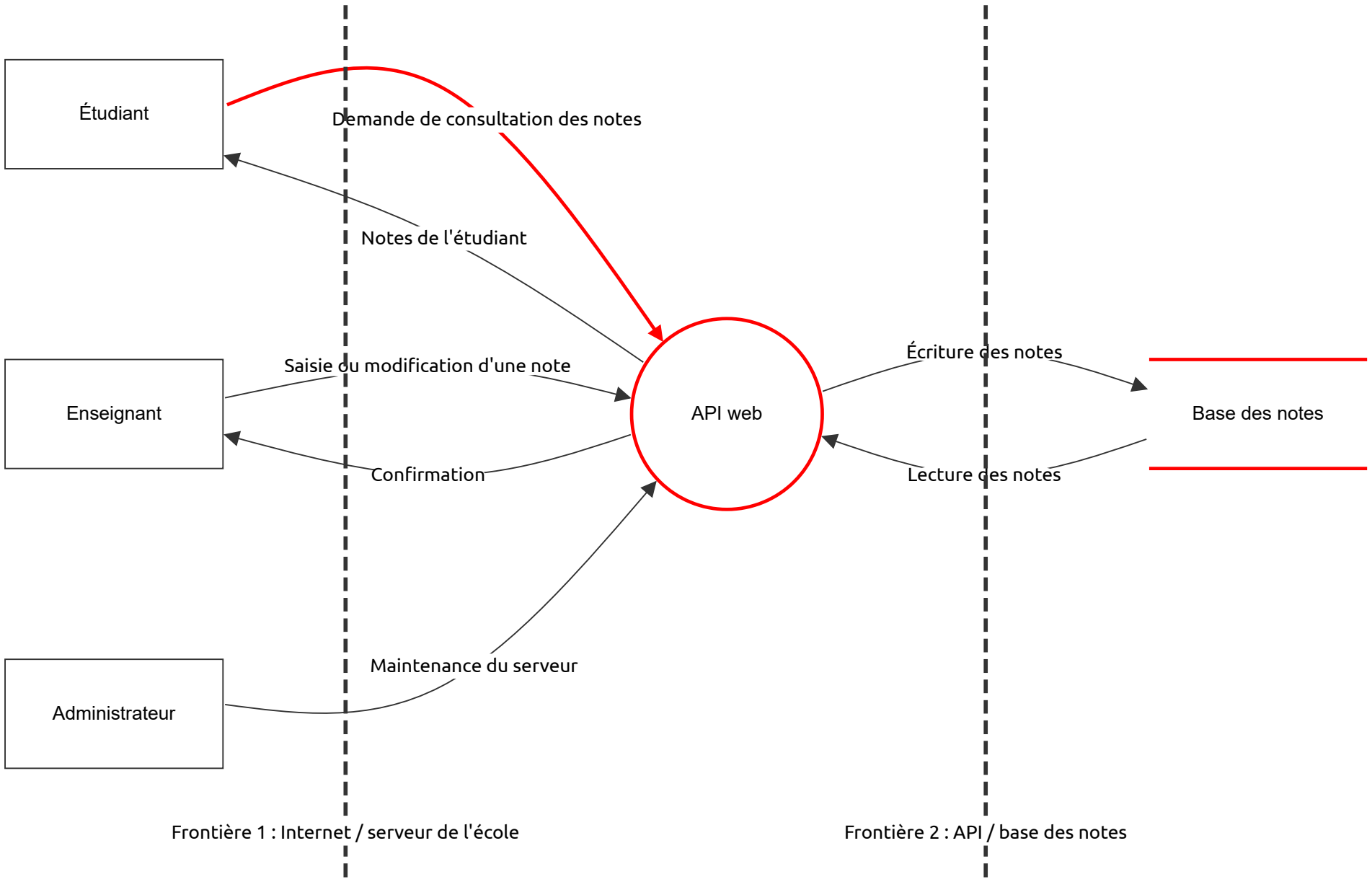
API web Python (Flask) qui permet aux étudiants de consulter leurs notes depuis leur téléphone et aux enseignants de saisir et modifier les notes de leur module. Les notes sont stockées dans une base SQLite (notes.db) sur le serveur de l'école, maintenu par un administrateur.

Summary

Total Threats	11
Total Mitigated	0
Total Open	11
Open / Critical Severity	2
Open / High Severity	4
Open / Medium Severity	5
Open / Low Severity	0

Flux de données

Échanges entre les utilisateurs, l'API web et la base des notes.



Flux de données

Étudiant (Actor)

Description: Consulte ses notes depuis son téléphone (4G ou Wi-Fi).

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Enseignant (Actor)

Description: Saisit et modifie les notes de son module depuis la salle des professeurs.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Administrateur (Actor)

Description: Maintient le serveur de l'école.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

API web (Process)

Description: Application Flask : identifie l'utilisateur, vérifie ses droits, lit et écrit les notes.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	Connexion avec le mot de passe volé d'un enseignant	Spoofing	High	Open		Un étudiant obtient le mot de passe d'un enseignant et se connecte à sa place pour modifier des notes.	Authentification forte (mot de passe + code), blocage après plusieurs échecs.
5	Un étudiant appelle directement la modification d'une note	Elevation of privilege	Critical	Open		L'application cache le bouton « Modifier » aux étudiants, mais l'API ne vérifie pas le rôle : un étudiant envoie la demande lui-même.	Vérifier sur chaque route de l'API que l'utilisateur a le bon rôle (autorisation).
6	Des milliers de requêtes le jour des résultats	Denial of service	Medium	Open		Un attaquant envoie un grand nombre de requêtes et bloque l'API au moment de la publication des résultats.	Limiter le nombre de requêtes par utilisateur et par minute.
7	Un enseignant nie avoir modifié une note	Repudiation	Medium	Open		Une note est modifiée et personne ne peut prouver qui l'a fait, car l'API n'enregistre aucune trace des modifications.	Journaliser chaque modification dans l'API : qui, quand, quelle note, ancienne et nouvelle valeur ; journal protégé contre la modification.
8	Messages d'erreur trop détaillés	Information disclosure	Medium	Open		En cas d'erreur, l'API renvoie le message technique (requête SQL, chemin de la base).	Renvoyer un message générique ; garder le détail dans les journaux du serveur.

Base des notes (Store)

Description: Fichier SQLite notes.db stocké sur le serveur de l'école.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	Note modifiée par injection SQL	Tampering	Critical	Open		Une saisie de l'utilisateur collée dans une requête SQL permet de modifier ou de supprimer des notes.	Requêtes paramétrées uniquement ; compte de base de données avec le moindre privilège.
10	Copie du fichier notes.db ou d'une sauvegarde	Information disclosure	High	Open		Quelqu'un qui accède au serveur ou à une sauvegarde copie le fichier et lit toutes les notes.	Chiffrement au repos ; droits d'accès au fichier limités à l'application.
11	Fichier notes.db supprimé ou corrompu	Denial of service	High	Open		Le fichier de la base est effacé ou abîmé (erreur, panne du disque, attaque) : plus personne ne peut consulter ni saisir de notes.	Sauvegardes régulières stockées à part et testées ; droits d'écriture sur le fichier limités à l'application.

Demande de consultation des notes (Data Flow)

Description: Requête de l'étudiant pour obtenir ses notes.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Interception des notes sur le Wi-Fi	Information disclosure	High	Open		Quelqu'un sur le même Wi-Fi lit les échanges envoyés en HTTP, sans chiffrement.	Chiffrer tous les échanges avec HTTPS (TLS).
2	Demande modifiée en chemin	Tampering	Medium	Open		La demande est modifiée pendant le transfert pour obtenir les notes d'un autre étudiant.	HTTPS, et vérification des droits côté serveur pour chaque demande.
3	Saturation du lien le jour des résultats	Denial of service	Medium	Open		Un grand nombre de demandes simultanées empêche les étudiants d'obtenir une réponse.	Limiter le nombre de requêtes par utilisateur ; prévoir la montée en charge.

Notes de l'étudiant (Data Flow)

Description: Réponse JSON contenant les notes.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Saisie ou modification d'une note (Data Flow)

Description: Nouvelle note envoyée par l'enseignant.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Confirmation (Data Flow)

Description: Réponse de l'API après l'enregistrement.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Maintenance du serveur (Data Flow)

Description: Connexion à distance de l'administrateur.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Écriture des notes (Data Flow)

Description: Requêtes SQL d'insertion et de modification.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Lecture des notes (Data Flow)

Description: Résultats des requêtes SQL de lecture.

Number	Title	Type	Severity	Status	Score	Description	Mitigations